Microsoft 365 Security Baseline & Audit Readiness (Secure Score / Compliance Manager) — Government (GCC High)

Implementation Solution Guide

Version 1.0.0 · 2026-07-01

Contents

Executive Summary — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High) 4

- The problem . . . 4
- The solution . . . 4
- How it works . . . 4
- What you get . . . 4
- Why it matters . . . 5

Solution Overview — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High) 5

- What this solution does . . . 5
- The two engines . . . 5
- Commercial vs GCC High — what's different . . . 6
- The deployment model . . . 7
- What you will produce . . . 7
- What's inside this solution . . . 8

Requirements Guide — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High) 8

- R1. A GCC High (US sovereign) tenant — not Commercial, not GCC Moderate . . . 9
- R2. US Government (Gov) licensing — G3/G5 Gov, not Commercial SKUs . . . 9
- R3. Administrative roles (least privilege) in the sovereign tenant . . . 9
- R4. Microsoft Defender portal access (Secure Score home) . . . 9
- R5. Microsoft Purview portal access (Compliance Manager home) . . . 10
- R6. Microsoft Graph PowerShell, connected to US Gov . . . 10
- R7. Least-privilege Graph scopes consented for this tenant . . . 10
- R8. Network access to the *sovereign* Microsoft cloud endpoints . . . 10
- R9. A named pilot security group . . . 11
- R10. Change control for authentication-impacting changes . . . 11

Implementation Guide — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High) 11

- Phase 0 — Assess (read-only discovery) . . . 12
- Phase 1 — Configure (stage the baseline, create named objects) . . . 12
- Phase 2 — Pilot (apply to the named pilot group only) . . . 13
- Phase 3 — Validate (prove it worked, prove nothing broke) . . . 14
- Phase 4 — Expand (controlled waves to the tenant) . . . 14
- Optional — Safe remediation via script . . . 15
- Ordering summary . . . 15

Testing & Validation — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High) 15
Test environment sanity checks (run first) . . . 15
Phase 0 — Assess gate . . . 16
Phase 1 — Configure gate . . . 16
Phase 2 — Pilot gate . . . 17
Phase 3 — Validate gate . . . 17
Phase 4 — Expand gate (per wave) . . . 17
Remediation script test (if used) . . . 18
End-to-end acceptance . . . 18
Troubleshooting — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High) 18
A. Sign-in, portal, and "wrong cloud" issues . . . 19
B. Microsoft Graph / PowerShell issues . . . 19
C. Secure Score issues . . . 20
D. Compliance Manager issues . . . 21
E. Rollout / lockout issues . . . 21
F. First things to check (fast triage) . . . 21
Best Practices — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High) 22
Sovereign-endpoint discipline . . . 22
Pilot-first, always . . . 22
Secure Score hygiene . . . 22
Compliance Manager & audit evidence . . . 23
Least privilege & operations . . . 23
Change management & documentation . . . 24
Deliverables Summary — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High) 24
Documents . . . 24
PowerShell scripts . . . 24
Named objects you create and reuse . . . 25
Evidence you produce (archive for audit) . . . 25
Quick-start order . . . 26
Appendix A — PowerShell Scripts 27

Executive Summary — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High)

The problem

Government and defense organizations on **Microsoft 365 GCC High** must demonstrate a hardened, auditable security posture — for **CMMC, NIST SP 800-171, FedRAMP, and DFARS** obligations. The trap is subtle: **GCC High is not the Commercial cloud with a different login.** It is an isolated US sovereign cloud with **its own admin portals (`*.us`), its own Microsoft Graph endpoints, and a feature set that lags or omits some Commercial capabilities.** Teams that follow Commercial guides or run downloaded Commercial scripts hit **silent failures** — tools authenticate against the wrong cloud, or chase recommendations that don't exist in GCC High — and end up with a posture that is neither correct nor defensible at audit.

The solution

This is the **Government (GCC High) edition** of the Microsoft 365 Security Baseline & Audit Readiness solution. It drives two engines, correctly, on the sovereign cloud:

- **Microsoft Secure Score** (`https://security.microsoft.us`) to raise and hold a measurable, hardened

baseline — using the improvement actions that are **actually available in GCC High**.

- **Microsoft Purview Compliance Manager** (`https://compliance.microsoft.us`) to organize audit

evidence against included templates — the **Microsoft Data Protection Baseline** and, with **G5 (Gov)**, **CMMC Levels 1–5**.

Every step uses the **`*.us` portals** and the **US Gov Graph** (`Connect-MgGraph -Environment USGov` → `graph.microsoft.us`). Every **Commercial-vs-GCC-High parity gap is cited** to Microsoft documentation, and anything Microsoft doesn't explicitly confirm is flagged **"verify for GCC High"** — never invented.

How it works

A novice administrator is guided click-by-click through the gated model **Assess** → **Configure** → **Pilot** → **Validate** → **Expand**. Changes are piloted against a **named group (`SEC-Baseline-Pilot`)** before any tenant-wide rollout — essential in GCC High, where a locked-out cleared user has no Commercial fallback. **Five read-safe PowerShell scripts** (Discovery, Validation, Report; plus Remediation and Set-ScopeTargeting, both defaulting to `-WhatIf`) produce repeatable, audit-grade evidence, all pinned to the US Gov endpoints.

What you get

- A **documented Secure Score baseline** on the GCC High tenant and a prioritized, GCC-High-real

improvement backlog.

• A **Compliance Manager assessment** (Data Protection Baseline; CMMC with G5 Gov) with evidence organized for audit.

• **Repeatable scripts and reports** so posture can be re-measured on demand and handed to an auditor.

• A **cited parity reference** so no one wastes time chasing capabilities GCC High doesn't have.

Why it matters

A fraction of the cost of bespoke consulting, self-guided, and **correct for the sovereign cloud** — so a Government tenant is configured with the right portals, the right endpoints, and the parity gaps handled, and proven on a pilot before it scales.

Solution Overview — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High)

What this solution does

This is the **Government (GCC High)** edition of the *Microsoft 365 Security Baseline & Audit Readiness* solution. It walks a novice administrator, click by click, through raising and holding a measurable Microsoft 365 security posture on a **US sovereign cloud (GCC High)** tenant — using **Microsoft Secure Score** to drive a hardened baseline, and **Microsoft Purview Compliance Manager** to organize the evidence that auditors ask for (CMMC, NIST SP 800-171, FedRAMP, DFARS).

The important thing to understand up front: **GCC High is not "the Commercial portal with a different sign-in."** It is a physically and logically isolated national cloud, operated by screened US personnel, with its **own admin portal URLs, its own Microsoft Graph endpoints, and a feature set that lags or omits some Commercial capabilities.** Commercial click-paths and scripts will *silently fail* or point at the wrong tenant if used here. This edition uses the `*.us` **sovereign portals** and the **US Gov Graph endpoints (**`-Environment USGov`**)** throughout, and calls out every parity gap at the step where it matters.

> ***White-label note.*** *This document is vendor-neutral. Object names it tells you to create (groups, policies, tags) are yours to keep and reuse across the solution.*

The two engines

1. **Microsoft Secure Score** (in the **Microsoft Defender portal**, `https://security.microsoft.us`)

— a running measurement of your identity, device, app, and data security configuration, expressed as points earned vs. points achievable, with prioritized improvement actions. In GCC High, Secure Score is **available**, but **some recommendations that exist in Commercial are not surfaced** — so your achievable total and your action list will differ from a Commercial tenant. (Verify for GCC High; cited in `gcc-high-parity-notes.md`.)

1. **Microsoft Purview Compliance Manager** (in the **Microsoft Purview portal**,

`https://compliance.microsoft.us`) — a control-mapping and evidence workspace that scores your compliance posture against **assessment templates**. In GCC High, Compliance Manager is **available**, the **Microsoft Data Protection Baseline** is included, and **CMMC Levels 1–5** are included with **G5 (Gov)** licensing — but a few Compliance Manager features are still *in development* or *rolling out* for GCC High (see parity notes).

Commercial vs GCC High — what's different

This is the single most important section for a Government deployment. Read it before touching anything.

Thing	Commercial	GCC High (this edition)
Entra admin center	`https://entra.microsoft.com`	`https://entra.microsoft.us`
Microsoft 365 admin center	`https://admin.microsoft.com`	`https://portal.office365.us`
Defender portal (Secure Score)	`https://security.microsoft.com`	`https://security.microsoft.us`
Purview / Compliance portal (Compliance Manager)	`https://compliance.microsoft.com`	`https://compliance.microsoft.us`
Intune / endpoint	`https://intune.microsoft.com` / `https://endpoint.microsoft.com`	`https://intune.microsoft.us` / `https://endpoint.microsoft.us`
Azure portal	`https://portal.azure.com`	`https://portal.azure.us`
Sign-in / token authority	`https://login.microsoftonline.com`	`https://login.microsoftonline.us`
Microsoft Graph service root	`https://graph.microsoft.com`	`https://graph.microsoft.us` (GCC High / L4)
Graph PowerShell connect	`Connect-MgGraph` (default)	`Connect-MgGraph -Environment USGov`
Defender for Endpoint API	`https://api.securitycenter.microsoft.com`	`https://api-gov.securitycenter.microsoft.us`
Secure Score recommendations	Full set	**Available, but some recommendations are not present**
Microsoft Threat Experts	Available	**Not available** in GCC/GCC High/DoD

Thing	Commercial	GCC High (this edition)
Defender for IoT (enterprise IoT)	Available	**Not available** in GCC/GCC High/DoD
Compliance Manager templates	Full catalog	Available; **CMMC L1–5 included with G5 Gov**; some CM features *in development / rolling out*
Graph Explorer web tool	Supported	**Not supported** for the US Gov endpoints

> *Sources for the URLs, Graph endpoints, and parity statements are cited in* `gcc-high-parity-notes.md`*. Where Microsoft's public documentation does not explicitly confirm a GCC High behavior, this solution flags it* ***"verify for GCC High"*** *rather than inventing a fact.*

Why this matters in practice: if you (or a downloaded Commercial script) connect to `graph.microsoft.com` with GCC High credentials, authentication is attempted against the *Commercial* authority and fails — often with a confusing redirect or "wrong tenant" error. If you open `security.microsoft.com`, you either land in a Commercial tenant you don't own or get an access error. Every step and every script in this edition is pinned to the sovereign endpoints so this class of "silent failure" cannot happen.

The deployment model

Every task in this solution follows the standard, gated model:

Assess → **Configure** → **Pilot** → **Validate** → **Expand.**

- **Assess** — read-only discovery of the current GCC High tenant (baseline Secure Score, licensing, roles, existing policies) using `M365SECG-Discovery.ps1`.
- **Configure** — create the named objects (pilot group, baseline policies) and stage improvement actions, using the correct `*.us` portals.
- **Pilot** — apply changes to a **named pilot group** first, never the whole tenant.
- **Validate** — confirm with `M365SECG-Validation.ps1` and the Secure Score / Compliance Manager UI that the change took effect and nothing broke.
- **Expand** — widen scope in controlled waves, re-validating at each **gate** before proceeding.

No change goes tenant-wide without passing a pilot and a validation gate. This is doubly important in GCC High, where an authentication-impacting misconfiguration can lock out cleared users who have no Commercial fallback.

What you will produce

- A **named pilot security group** (default: `SEC-Baseline-Pilot`) used across the solution.

• A raised, **documented Secure Score baseline** on the GCC High tenant, with a prioritized backlog of the improvement actions that are actually available in GCC High.

• A **Compliance Manager assessment** (default: Microsoft Data Protection Baseline, plus CMMC if G5 Gov) with evidence organized for audit.

• **Repeatable evidence**: discovery, validation, and report outputs from the five PowerShell scripts, all pinned to US Gov Graph — so the posture can be re-measured on demand and handed to an auditor.

What's inside this solution

• **Solution Overview** (this document) — with the Commercial-vs-GCC-High map above.

• **Requirements Guide** (`02-requirements.md`) — every prerequisite, each with *verify* and *implement-if-missing* steps, pinned to sovereign portals and Gov licensing.

• **Implementation Guide** (`03-implementation.md`) — exact ordered steps in the `*.us` portals, with GCC-High-only caveats inline at the step where they bite.

• **Testing & Validation** (`05-testing.md`) — pass/fail gates for each phase.

• **Best Practices** (`07-best-practices.md`) — how to keep the posture from decaying.

• **Deliverables Summary** (`08-deliverables-summary.md`) — everything in the box.

• **GCC High Parity Notes** (`gcc-high-parity-notes.md`) — the cited reference for every "different in GCC High" claim.

• **Troubleshooting** (`06-troubleshooting.md`) — GCC-High-specific gotchas and fixes.

• **5 PowerShell scripts** — Discovery, Validation, Report (read-only), Remediation and Set-ScopeTargeting (both default to `-WhatIf`), all connecting with `-Environment USGov`.

Requirements Guide — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High)

Confirm every requirement below **before** you begin implementation. These are **in addition to** the category-level requirements in `global-requirements-security.md` — read that file too, but note that its portal URLs are Commercial and must be **substituted with the `*.us` sovereign equivalents** shown here for a GCC High tenant.

Each entry follows: **Description · Why · Verify · Implement-if-missing.**

> ***Sovereign-portal substitution (applies to every requirement below).*** *Wherever a Commercial doc says* `entra.microsoft.com`*, use* `entra.microsoft.us`*;* `admin.microsoft.com` → `portal.office365.us`*;* `security.microsoft.com` → `security.microsoft.us`*;* `compliance.microsoft.com` → `compliance.microsoft.us`*;* `intune.microsoft.com`/`endpoint.microsoft.com` → `intune.microsoft.us`/`endpoint.microsoft.us`*;* `portal.azure.com` → `portal.azure.us`*;*

`login.microsoftonline.com` → `login.microsoftonline.us`. *(Cited in `gcc-high-parity-notes.md`.)*

R1. A GCC High (US sovereign) tenant — not Commercial, not GCC Moderate

Description: An active **Microsoft 365 Government – GCC High** tenant. **Why:** This entire edition targets the L4 sovereign cloud. GCC High has its own endpoints and feature set; Commercial or GCC-Moderate steps will point at the wrong cloud. (Note: **GCC Moderate uses the *worldwide* Commercial endpoints** — `portal.azure.com`, `graph.microsoft.com` — so if you are on GCC Moderate, this GCC High edition's `*.us` endpoints do **not** apply to you.) **Verify:** Sign in at `https://portal.office365.us`. In the Microsoft 365 admin center, your tenant type/region should reflect US Government GCC High. Signing in at `https://entra.microsoft.us` succeeds (the Commercial `entra.microsoft.com` will not host your GCC High tenant). **Implement:** GCC High requires eligibility validation and enrollment through Microsoft's Government program; you cannot self-provision it like a Commercial trial. If you do not yet have a GCC High tenant, complete Microsoft's Government eligibility and onboarding first. (See parity notes.)

R2. US Government (Gov) licensing — G3/G5 Gov, not Commercial SKUs

Description: Gov-variant Microsoft 365 licensing that carries Secure Score and Compliance Manager. **Why:** Secure Score (via Defender) and Compliance Manager assessments depend on Gov SKUs. **CMMC Levels 1–5 assessment templates are included with G5 (Gov)** licensing; the **Microsoft Data Protection Baseline** is included for all. Commercial E3/E5 SKUs are **not** valid in a GCC High tenant. **Why (Secure Score):** Full device/app recommendations require the Gov Defender SKUs (for example **Microsoft 365 E5 for GCC High** or **Microsoft 365 G5 Security for GCC High**, or **Microsoft Defender for Endpoint for GCC High**). **Verify:** `https://portal.office365.us` → **Billing** → **Licenses**; confirm Gov SKUs (names contain "GCC High" or "for GCC High"). Confirm at least one G5 Gov / G5 Security Gov license if you intend to use CMMC templates. **Implement:** Acquire the appropriate Gov SKUs via your Government licensing channel. Do not attempt to add Commercial SKUs.

R3. Administrative roles (least privilege) in the sovereign tenant

Description: The operator holds the right Entra roles, assigned in the **GCC High** directory. **Why:** Reading Secure Score, editing improvement actions, and managing Compliance Manager each need specific roles. In **GCC High and DoD, Compliance Manager user permissions/roles can only be set in Microsoft Entra ID** (not in the portal's own role UI as in Commercial). **Verify:** `https://entra.microsoft.us` → **Roles and administrators**. For this solution you typically need: **Security Reader** (read Secure Score/Compliance), **Security Administrator** (act on improvement actions), and for Compliance Manager a **Compliance Administrator** / **Compliance Manager** role assigned **in Entra**. Reserve **Global Administrator** for tenant-wide changes only. **Implement:** In `entra.microsoft.us` → **Roles and administrators**, assign the least-privilege role that covers the task. Use **Privileged Identity Management (PIM)** for just-in-time elevation if available on your Gov SKU.

R4. Microsoft Defender portal access (Secure Score home)

Description: The operator can open the **sovereign** Defender portal. **Why:** Secure Score lives at `https://security.microsoft.us` in GCC High — **not** `security.microsoft.com`. **Verify:**

Browse to `https://security.microsoft.us` and confirm it loads your tenant and that **Microsoft Secure Score** appears in the left navigation. **Implement:** If it does not load, confirm R2/R3 (Gov license + Security Reader/Administrator) and that you are signing in with a **GCC High** account against `login.microsoftonline.us`.

R5. Microsoft Purview portal access (Compliance Manager home)

Description: The operator can open the **sovereign** Purview/Compliance portal. **Why:** Compliance Manager lives at `https://compliance.microsoft.us` in GCC High. **Verify:** Browse to `https://compliance.microsoft.us` → **Compliance Manager**; confirm your overall score and the **assessments** list render. **Implement:** If blocked, confirm the Compliance role is assigned **in Entra** (R3) and the Gov license (R2) is present.

R6. Microsoft Graph PowerShell, connected to US Gov

Description: The Microsoft Graph PowerShell SDK installed and connecting with `-Environment USGov`. **Why:** All five scripts read/write through Graph. In GCC High the Graph service root is `https://graph.microsoft.us`, reached by `Connect-MgGraph -Environment USGov`. Omitting `-Environment USGov` connects to Commercial and **fails** for a GCC High tenant. **Verify:** In PowerShell: `Get-MgEnvironment` lists a `USGov` environment whose Graph endpoint is `https://graph.microsoft.us`. Then `Connect-MgGraph -Environment USGov -Scopes "SecurityEvents.Read.All"` succeeds and `(Get-MgContext).Environment` returns `USGov`. **Implement:** `Install-Module Microsoft.Graph -Scope CurrentUser` (from an elevated or user PowerShell with access to the PowerShell Gallery). If the Gallery is blocked by filtering, allow it or use an offline package. Always pass `-Environment USGov`.

R7. Least-privilege Graph scopes consented for this tenant

Description: The delegated Graph scopes the scripts need are consented in the GCC High tenant. **Why:** Read scopes power discovery/validation/report; a small set of write scopes power remediation. **Verify:** First `Connect-MgGraph -Environment USGov` run prompts for (or shows already-consented) scopes such as `SecurityEvents.Read.All`, `Directory.Read.All`, `Policy.Read.All`, `RoleManagement.Read.Directory`. Remediation additionally needs write scopes (for example `Policy.ReadWrite.ConditionalAccess`), which the remediation script requests explicitly. **Implement:** A Global Administrator (or Privileged Role Administrator) grants admin consent in `entra.microsoft.us` → **App registrations / Enterprise applications** the first time, or approves the interactive consent prompt. Grant **only** the scopes the task requires.

R8. Network access to the *sovereign* Microsoft cloud endpoints

Description: Outbound HTTPS to the `*.us` service URLs (not just the Commercial ones). **Why:** GCC High enrollment, sign-in, Graph, and Defender/Compliance traffic use **different hostnames** than Commercial. A firewall/proxy allow-list built for Commercial will block GCC High. **Verify:** From an admin workstation, confirm reachability of `https://login.microsoftonline.us`, `https://graph.microsoft.us`, `https://security.microsoft.us`, and `https://compliance.microsoft.us`. **Implement:** Add Microsoft's published **US Government** (GCC High/DoD) URL and IP ranges to the proxy/firewall allow-list. Do not assume the Commercial 365 URL set covers GCC High.

R9. A named pilot security group

Description: A Microsoft Entra security group for the pilot cohort (default name: `SEC-Baseline-Pilot`). **Why:** Every baseline/policy change is piloted before tenant-wide rollout. In GCC High, an auth-impacting mistake has no Commercial fallback, so the pilot gate is mandatory. **Verify:** `https://entra.microsoft.us` → **Groups**; `SEC-Baseline-Pilot` exists with a small set of representative members. **Implement:** `entra.microsoft.us` → **Groups** → **New group** → type **Security**, name it `SEC-Baseline-Pilot`, add pilot members. (Script `M365SECG-Set-ScopeTargeting.ps1` can create/populate it — it defaults to `-WhatIf`.)

R10. Change control for authentication-impacting changes

Description: A documented change/rollback process for anything touching sign-in, Conditional Access, MFA, or device compliance. **Why:** Secure Score improvement actions frequently harden authentication; a misstep can lock out cleared users. GCC High offers no Commercial-cloud escape hatch. **Verify:** A change ticket exists naming an approver, a maintenance window, the pilot group, and a concrete rollback step. **Implement:** Record the change, name `SEC-Baseline-Pilot` as the pilot scope, define the rollback, and obtain approval before expanding beyond pilot.

Requirements quick-check

#	Requirement	Sovereign verify location
R1	GCC High tenant	`portal.office365.us`, `entra.microsoft.us`
R2	Gov licensing (G3/G5 Gov)	`portal.office365.us` → Billing → Licenses
R3	Admin roles (set in Entra)	`entra.microsoft.us` → Roles and administrators
R4	Defender portal access	`security.microsoft.us`
R5	Purview portal access	`compliance.microsoft.us`
R6	Graph PowerShell `-Environment USGov`	`Get-MgContext` → `USGov`
R7	Graph scopes consented	first `Connect-MgGraph -Environment USGov`
R8	Network to `*.us` endpoints	reach `graph.microsoft.us` etc.
R9	Pilot group `SEC-Baseline-Pilot`	`entra.microsoft.us` → Groups
R10	Change control	change ticket exists

Implementation Guide — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High)

This guide takes you, step by step, through raising and documenting your Microsoft 365 security posture on a **GCC High** tenant using **Microsoft Secure Score** and **Microsoft Purview Compliance Manager**. Every step uses the **sovereign** `*.us` **portals** and the **US Gov Graph endpoints**. Do the phases in order; each phase ends at a **gate** you must pass before continuing.

> ***Before you start.*** *Complete* `02-requirements.md`*. Have your operator account signed in against* `login.microsoftonline.us`*, and have the Microsoft Graph PowerShell SDK ready to connect with* `-Environment USGov` *(R6). Keep the named pilot group* `SEC-Baseline-Pilot` *handy (R9).*
> ***GCC-High reality check (read once):*** *the parity gaps in* `gcc-high-parity-notes.md` *are cited from Microsoft docs. Where a Commercial improvement action simply does not appear in your GCC High Secure Score, that is expected — do not chase a recommendation that isn't there. Treat anything this guide marks* ***"verify for GCC High"*** *as something to confirm live in your tenant, not assume.*

Phase 0 — Assess (read-only discovery)

Goal: capture the starting state of the GCC High tenant with zero changes.

1. **Open the sovereign Defender portal.** Browse to `https://security.microsoft.us`. In the left

navigation, open **Microsoft Secure Score**. Note the current **score**, the **percentage**, and the number of **improvement actions**. Screenshot the overview — this is your **baseline**.

• *GCC-High caveat:* your achievable total and action list will differ from a Commercial tenant

because **some Secure Score recommendations are not surfaced in GCC High** (parity notes). Do not compare your number to a Commercial benchmark.

1. **Open the sovereign Purview portal.** Browse to `https://compliance.microsoft.us` →

Compliance Manager. Note your **overall compliance score** and which **assessments** already exist. Screenshot the overview.

1. **Run read-only discovery.** From PowerShell, run:

```
powershell -ExecutionPolicy Bypass -File .\M365SECG-Discovery.ps1
```

It connects with `-Environment USGov`, then inventories: Secure Score (current + control profiles), licensing, admin role assignments, Conditional Access policies, and MFA/registration posture — all read-only. Save its output as your evidence baseline.

Gate 0: You have a screenshot + script capture of the **current** Secure Score, the current Compliance Manager score, and the tenant inventory. Nothing has been changed.

Phase 1 — Configure (stage the baseline, create named objects)

Goal: decide the target baseline and create the objects you'll reuse, without applying anything tenant-wide yet.

1. **Confirm / create the pilot group.** In `https://entra.microsoft.us` → **Groups**, confirm

`SEC-Baseline-Pilot` exists (R9). If not, create it (**New group** → **Security**) or use `M365SECG-Set-ScopeTargeting.ps1` (defaults to `-WhatIf`; re-run with `-Execute` to apply).

1. **Pick your Compliance Manager assessment(s).** In `compliance.microsoft.us` → **Compliance

Manager → Assessments → Add assessment**:

• The **Microsoft Data Protection Baseline** is included for everyone — start here.

• If you hold **G5 (Gov)** licensing and pursue defense work, add **CMMC** (Levels 1–5 are included

with G5 Gov) and/or **NIST SP 800-171**. Name the assessment clearly (e.g. `GCCHigh-DPB-Baseline` or `GCCHigh-CMMC-L2`).

• *GCC-High caveat:* a few Compliance Manager features (for example **alerts and notifications**,

recommended engine for bulk assessment creation) are listed as *in development / rolling out* for GCC High — if you don't see them yet, that's expected (parity notes).

1. **Triage Secure Score improvement actions.** Back in `security.microsoft.us` → **Secure Score →

Improvement actions**, sort by** points + impact**. Build a prioritized backlog of the actions that are** actually present** in your GCC High tenant. Favor high-value identity actions first (MFA for admins, block legacy authentication, admin role hygiene) — these move the score and reduce real risk fastest.

• For each action, note whether it is configured via **Entra** (Conditional Access / auth methods),

Defender, **Purview**, or **Intune** — and use the corresponding `*.us` portal.

1. **Write the change ticket** (R10) for the first batch of actions: approver, maintenance window,

pilot scope = `SEC-Baseline-Pilot`, and a rollback step per action.

Gate 1: Pilot group exists; at least one Compliance Manager assessment is created and named; you have a prioritized, GCC-High-real Secure Score backlog and an approved change ticket for batch 1.

Phase 2 — Pilot (apply to the named pilot group only)

Goal: apply batch 1 of improvement actions to `SEC-Baseline-Pilot` only.

1. **Scope every change to the pilot group.** For actions delivered via Conditional Access or auth

methods, in `entra.microsoft.us` create/edit the policy so its **assignment targets** `SEC-Baseline-Pilot`, not All users. Give each policy a clear, reusable name (e.g. `CA-Baseline-Admins-MFA`, `CA-Baseline-BlockLegacyAuth`).

• *GCC-High caveat:* Conditional Access and authentication-method features generally reach GCC High,

but confirm the **specific** control you need is present in your tenant before relying on it (**verify for GCC High**).

1. **Apply device/app actions to piloted devices.** For Intune-delivered actions, in

`intune.microsoft.us` assign the configuration/compliance policy to `SEC-Baseline-Pilot`.

• *GCC-High caveat:* **Microsoft Threat Experts** and **enterprise IoT** Defender features are

not available in GCC High — do not stage improvement actions that depend on them; they won't appear or won't complete (parity notes).

1. **Record what you changed.** Keep the change ticket updated with the exact policy names and the pilot assignment.

Gate 2: Batch 1 actions are applied **only** to `SEC-Baseline-Pilot`. No All-users / tenant-wide assignment has been made.

Phase 3 — Validate (prove it worked, prove nothing broke)

Goal: confirm the pilot changes took effect and produced the intended posture change.

1. **Run validation.** From PowerShell:

```
powershell -ExecutionPolicy Bypass -File .\M365SECG-Validation.ps1
```

It reconnects with `-Environment USGov` and checks the pilot state: are the named CA policies present and enabled? Is the pilot group targeted? Have the expected control states flipped? It reports **PASS/FAIL per check**.

1. **Confirm in the UI.** In `security.microsoft.us` → **Secure Score** → **History**, confirm the score moved (Secure Score updates can lag up to ~24–48 hours; re-check the next day if needed — **verify for GCC High**, as Gov refresh cadence may differ). In `compliance.microsoft.us` → Compliance Manager, confirm improvement actions on your assessment show as implemented/tested.

1. **Confirm no user impact.** Verify pilot users can still sign in and reach their apps. If any pilot user is blocked, **execute the rollback** from the change ticket immediately, then diagnose (see `06-troubleshooting.md`).

Gate 3: Validation script reports PASS for batch 1; Secure Score/Compliance Manager reflect the change; **no pilot user is locked out**.

Phase 4 — Expand (controlled waves to the tenant)

Goal: widen scope beyond the pilot in gated waves.

1. **Widen scope one wave at a time.** Change the policy assignment from `SEC-Baseline-Pilot` to the next cohort (e.g. a department group, then all users). Use `M365SECG-Set-ScopeTargeting.ps1` to build/target the next group (defaults to `-WhatIf`; re-run with `-Execute` to apply).

1. **Re-validate at each wave.** Re-run `M365SECG-Validation.ps1` after each expansion. Do **not** proceed to the next wave until the current one passes and no lockouts are reported.

1. **Move to the next batch of improvement actions.** Repeat Phases 1–4 for the next prioritized batch from your Secure Score backlog.

1. **Produce the audit report.** When a milestone is reached, run:

```
powershell -ExecutionPolicy Bypass -File .\M365SECG-Report.ps1
```

It generates a point-in-time posture report (Secure Score summary, control states, assessment progress) suitable for handing to an auditor or leadership.

Gate 4: Each expansion wave passed validation with no lockouts; the report has been generated and archived as evidence.

Optional — Safe remediation via script

For a small set of common, well-understood improvement actions, `M365SECG-Remediation.ps1` can apply changes through Graph. It **defaults to** `-WhatIf` (it only *previews* what it would do). Review the preview, ensure the change is in your approved ticket and scoped to `SEC-Baseline-Pilot`, then re-run with `-Execute` to apply. It connects with `-Environment USGov` and requests only the write scopes it needs.

> ***Never*** *run remediation with* `-Execute` *against All users on a first pass. Pilot → validate → expand, exactly as with portal changes.*

Ordering summary

Phase	Portal(s) `*.us`	Script	Gate
0 Assess	security, compliance	Discovery	Baseline captured, nothing changed
1 Configure	entra, security, compliance	(Set-ScopeTargeting `-WhatIf`)	Objects + backlog + ticket ready
2 Pilot	entra, intune	(Remediation `-WhatIf`→`-Execute`)	Applied to pilot only
3 Validate	security, compliance	Validation	PASS, no lockouts
4 Expand	entra, intune	Set-ScopeTargeting, Report	Each wave PASS, report archived

Testing & Validation — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High)

Testing is **gate-based**: each phase has a pass/fail check you must clear before moving on. All checks use the **sovereign** `*.us` **portals** and the **US Gov Graph** (`-Environment USGov`). If a check fails, stop and go to `06-troubleshooting.md` before proceeding.

> ***Golden rule for GCC High:*** *a check "failing" is sometimes actually* ***feature parity*** *— the Commercial control you expected may simply not exist in GCC High. Before treating a missing recommendation as a defect, confirm against* `gcc-high-parity-notes.md` *(****verify for GCC High****).*

Test environment sanity checks (run first)

#	Check	How	Pass
E1	You're in the sovereign cloud	`https://security.microsoft.us` loads your tenant	Portal shows your GCC High org, Secure Score visible
E2	Graph is on US Gov	PowerShell: `(Get-MgContext).Environment` after `Connect-MgGraph -Environment USGov`	Returns `USGov`
E3	Graph root is correct	`Get-MgEnvironment`	`USGov` row shows `https://graph.microsoft.us`
E4	Compliance portal reachable	`https://compliance.microsoft.us` → Compliance Manager	Overall score + assessments render

If **E2** returns anything other than `USGov`, **every** subsequent script result is invalid — you are querying the wrong cloud. Disconnect (`Disconnect-MgGraph`) and reconnect with `-Environment USGov`.

Phase 0 — Assess gate

#	Check	How	Pass
T0.1	Baseline Secure Score captured	`security.microsoft.us` → Secure Score; screenshot	Score, %, action count recorded
T0.2	Baseline Compliance score captured	`compliance.microsoft.us` → Compliance Manager	Overall score recorded
T0.3	Discovery ran clean	`.\M365SECG-Discovery.ps1`	Completes; output file written; connected as `USGov`
T0.4	No changes made	Review discovery is read-only	No write operations performed

Gate 0 passes when T0.1–T0.4 are all green.

Phase 1 — Configure gate

#	Check	How	Pass
T1.1	Pilot group exists	`entra.microsoft.us` → Groups → `SEC-Baseline-Pilot`	Group present with pilot members
T1.2	Assessment created	`compliance.microsoft.us` → Compliance Manager → Assessments	Named assessment (e.g. `GCCHigh-DPB-Baseline`) present

#	Check	How	Pass
T1.3	Backlog is GCC-High-real	Secure Score → Improvement actions	Backlog contains only actions that exist in *your* tenant
T1.4	Change ticket approved	Ticketing system	Approver, window, pilot scope, rollback documented

Gate 1 passes when T1.1–T1.4 are all green.

Phase 2 — Pilot gate

#	Check	How	Pass
T2.1	Policies scoped to pilot	`entra.microsoft.us` → policy assignment	Assignment = `SEC-Baseline-Pilot`, **not** All users
T2.2	Named consistently	Policy list	Names reused per plan (e.g. `CA-Baseline-Admins-MFA`)
T2.3	No parity-blocked actions staged	Cross-check parity notes	No action depends on Threat Experts / enterprise IoT (absent in GCC High)

Gate 2 passes when T2.1–T2.3 are all green **and** no tenant-wide assignment was made.

Phase 3 — Validate gate

#	Check	How	Pass
T3.1	Validation script PASS	`.\M365SECG-Validation.ps1`	Every check reports PASS for batch 1
T3.2	Score moved	`security.microsoft.us` → Secure Score → History	Increase visible (allow ~24–48h refresh; **verify for GCC High**)
T3.3	Assessment progressed	`compliance.microsoft.us` → Compliance Manager	Batch-1 improvement actions show implemented/tested
T3.4	No user lockout	Pilot users sign in & reach apps	All pilot users unaffected

Gate 3 passes when T3.1–T3.4 are all green. **If T3.4 fails, execute rollback immediately.**

Phase 4 — Expand gate (per wave)

#	Check	How	Pass
T4.1	Wave scoped correctly	`entra.microsoft.us` / `intune.microsoft.us`	Assignment = current wave cohort only
T4.2	Re-validation PASS	`.\M365SECG-Validation.ps1`	PASS for the widened scope
T4.3	No lockout in wave	Sample users in the new cohort	All can sign in
T4.4	Report generated	`.\M365SECG-Report.ps1`	Point-in-time report produced and archived

Gate 4 passes when T4.1–T4.4 are green **for each wave**. Do not start the next wave until the current one passes.

Remediation script test (if used)

#	Check	How	Pass
RM.1	Default is safe	Run `.\M365SECG-Remediation.ps1` with no switches	Runs in `-WhatIf`; only previews, changes nothing
RM.2	Preview matches ticket	Read the `-WhatIf` output	Previewed change equals the approved action, scoped to pilot
RM.3	Execute is deliberate	Re-run with `-Execute`	Applies only after review; connected as `USGov`
RM.4	Post-change validation	`.\M365SECG-Validation.ps1`	PASS; no lockout

End-to-end acceptance

The solution is validated end-to-end when:

1. Baseline captured (Gate 0), and a **later** report shows a **measurable Secure Score increase** on the GCC High tenant.
1. At least one **Compliance Manager assessment** shows progressed improvement actions.
2. Every change went **pilot** → **validate** → **expand** with **no unresolved lockouts**.
3. All script runs confirm `(Get-MgContext).Environment` = `USGov` (never Commercial).
4. Evidence (discovery, validation, report outputs + screenshots) is archived for audit.

Troubleshooting — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High)

GCC-High-specific failures and how to fix them. Most problems on the sovereign cloud trace back to one root cause: **something is pointed at the Commercial cloud instead of the `*.us` sovereign endpoints.** Check that first, every time.

> *Before deep-diving any issue, run environment sanity checks E1–E4 in `05-testing.md`. If `(Get-MgContext).Environment` is not `USGov`, stop — that alone explains most "weird" results.*

A. Sign-in, portal, and "wrong cloud" issues

A1. A `*.us` portal won't load, or shows a tenant that isn't yours

- **Likely cause:** you signed in with a Commercial account, or the browser cached a Commercial session.
- **Fix:** sign out fully; sign in with your **GCC High** account against `login.microsoftonline.us` at the specific `*.us` portal (`security.microsoft.us`, `compliance.microsoft.us`, `entra.microsoft.us`). Use a fresh/incognito window to avoid cached Commercial tokens.

A2. `security.microsoft.com` / `compliance.microsoft.com` opens but Secure Score / Compliance Manager data is missing

- **Likely cause:** you're on the **Commercial** portal, not the sovereign one.
- **Fix:** switch to `security.microsoft.us` (Secure Score) and `compliance.microsoft.us` (Compliance Manager). GCC High data never appears in the `*.com` portals.

A3. `Connect-MgGraph` redirect / "wrong tenant" / "wrong version number" error

- **Likely cause:** you connected **without** `-Environment USGov`, so the SDK tried the Commercial authority for a GCC High account.
- **Fix:**

```
Disconnect-MgGraph
Connect-MgGraph -Environment USGov -Scopes "SecurityEvents.Read.All"
(Get-MgContext).Environment   # must return USGov
```

Confirm the env exists: `Get-MgEnvironment` should list `USGov` with Graph endpoint `https://graph.microsoft.us`.

A4. Script output looks plausible but numbers don't match the portal

- **Likely cause:** the script connected to Commercial (wrong cloud) and returned data from the wrong place — or from an empty/foreign context.
- **Fix:** every script in this solution guards on `(Get-MgContext).Environment -eq 'USGov'`. If you adapted a community script, add the same guard and re-point `graph.microsoft.com` → `graph.microsoft.us`. Re-run.

B. Microsoft Graph / PowerShell issues

B1. `Get-MgEnvironment` *doesn't list* `USGov`

- **Likely cause:** outdated Microsoft Graph SDK.
- **Fix:** update the module: `Update-Module Microsoft.Graph` (or reinstall `Install-Module Microsoft.Graph -Scope CurrentUser`). Restart PowerShell and re-check.

B2. `Install-Module Microsoft.Graph` *fails (can't reach the Gallery)*

- **Likely cause:** proxy/firewall blocks the PowerShell Gallery.
- **Fix:** allow the Gallery, or install from an offline package on an admin workstation that has access. Then confirm R8 network reachability to the `*.us` endpoints (not just Commercial).

B3. Consent / scope errors on first connect

- **Likely cause:** required delegated scopes aren't consented in the GCC High tenant.
- **Fix:** have a Global Administrator (or Privileged Role Administrator) approve the consent prompt, or pre-consent in `entra.microsoft.us` → Enterprise applications. Grant **only** the scopes the task needs (read for Discovery/Validation/Report; write only for Remediation).

B4. Remediation script "changed nothing"

- **This is expected.** `M365SECG-Remediation.ps1` and `M365SECG-Set-ScopeTargeting.ps1` **default to `-WhatIf`** — they only preview. Review the preview, confirm it matches your approved ticket, then re-run with `-Execute`.

C. Secure Score issues

C1. An improvement action you expected isn't in the list

- **Likely cause: feature parity** — some Secure Score recommendations **are not available in GCC High** (cited in `gcc-high-parity-notes.md`).
- **Fix:** confirm against the parity notes. If it's a known GCC High gap, record it as **"N/A — GCC High parity" **in your backlog; it is not a defect. Do** not **try to force an action that depends on** Microsoft Threat Experts **or** enterprise IoT** — those are absent in GCC High.

C2. Score didn't move after applying an action

- **Likely cause:** refresh lag, or the action was scoped to pilot only and Secure Score reflects tenant-wide state.
- **Fix:** allow ~24–48 hours and re-check **Secure Score** → **History** (**verify for GCC High** — Gov refresh cadence may differ). Confirm the control is actually in the state the action requires; some actions only credit at broader coverage.

C3. Defender API calls fail (if you script against the Defender API directly)

- **Likely cause:** using the Commercial API base URI.

• **Fix:** for **GCC High**, use `https://api-gov.securitycenter.microsoft.us` with sign-in authority `https://login.microsoftonline.us` (cited in parity notes). GCC uses `https://api-gcc.securitycenter.microsoft.us`.

D. Compliance Manager issues

D1. Can't assign Compliance Manager roles in the portal

• **Likely cause:** in **GCC High and DoD**, Compliance Manager **permissions/roles are set in Microsoft Entra ID**, not in the portal's own role UI.

• **Fix:** assign the Compliance role in `entra.microsoft.us` → Roles and administrators (cited in parity notes).

D2. A Compliance Manager feature described in Commercial docs is missing

• **Likely cause:** it's **in development / rolling out** for GCC High (e.g. **alerts and notifications**, recommended engine for bulk assessment creation**,** continuous compliance assessments**).

• **Fix:** confirm status in `gcc-high-parity-notes.md`. Don't build a process that depends on a feature that isn't live yet in GCC High.

D3. CMMC templates not available

• **Likely cause:** licensing. **CMMC Levels 1–5** templates are **included with G5 (Gov)**.

• **Fix:** confirm a **G5 Gov** license (R2). The **Microsoft Data Protection Baseline** is included for everyone and works without G5 — start there if you're on G3.

E. Rollout / lockout issues

E1. A pilot user is locked out after an auth-impacting change

• **Action: execute the rollback** from your change ticket immediately (disable/undo the named CA policy in `entra.microsoft.us`). Then diagnose in a controlled way before re-piloting. In GCC High there is **no Commercial fallback**, so treat any lockout as a stop-the-line event.

E2. Change worked in pilot but broke a broader wave

• **Likely cause:** the wider cohort includes a user/device type your pilot didn't represent.

• **Fix:** roll the wave back to the last-good scope, add the missing persona to `SEC-Baseline-Pilot`, re-pilot, re-validate, then expand again.

F. First things to check (fast triage)

1. **Are you on `*.us`?** Portal host and `(Get-MgContext).Environment = USGov`.

2. **Right account?** Signed in against `login.microsoftonline.us` with a GCC High account.
3. **Right license?** Gov SKU present (R2); G5 Gov if using CMMC.
4. **Role in Entra?** Least-privilege role assigned in `entra.microsoft.us` (and CM roles set in Entra).
5. **Is it parity, not a bug?** Cross-check `gcc-high-parity-notes.md` before filing a "missing feature."

Best Practices — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High)

These practices keep the posture you built from decaying and keep your audit evidence credible. They are written for the **GCC High** sovereign cloud; where a practice differs from Commercial, that is called out.

Sovereign-endpoint discipline

- **Pin every tool to the `*.us` portals and US Gov Graph.** Bookmark `security.microsoft.us`, `compliance.microsoft.us`, `entra.microsoft.us`, `intune.microsoft.us`, `portal.office365.us`, and `portal.azure.us`. Delete Commercial bookmarks from the admin workstation so no one drifts to `*.com` out of habit.
- **Always `Connect-MgGraph -Environment USGov`.** Bake it into every runbook and script. Add a guard that aborts if `(Get-MgContext).Environment -ne 'USGov'` — a script run against Commercial produces wrong-but-plausible output, which is worse than a clean failure.
- **Reject downloaded Commercial scripts as-is.** Community Secure Score / Compliance scripts almost always hardcode `graph.microsoft.com` and `security.microsoft.com`. Re-point them to the sovereign endpoints before running, or use the scripts shipped with this solution.

Pilot-first, always

- **Never make an auth-impacting change tenant-wide in one move.** MFA enforcement, blocking legacy auth, Conditional Access, and device-compliance gating all go **pilot** → **validate** → **expand**. In GCC High there is no Commercial fallback for locked-out cleared users.
- **Keep `SEC-Baseline-Pilot` populated with representative users** — at least one of each: admin, standard user, mobile-only user, and a service/shared-mailbox owner — so pilot surfaces real impact.
- **Write the rollback before you write the change.** Every change ticket names its own undo.

Secure Score hygiene

- **Prioritize by risk, not just points.** Lead with identity (admin MFA, block legacy auth, admin role minimization) — highest real-risk reduction per unit of effort.

• **Don't chase phantom recommendations.** Some Commercial Secure Score actions **do not exist in GCC

High**. Track only actions present in *your* tenant; annotate the backlog "N/A — GCC High parity" for the rest so auditors see it was a conscious decision, not an oversight.

• **Re-measure on a cadence.** Secure Score drifts as admins add exceptions and new services appear.

Re-run `M365SECG-Report.ps1` monthly and diff against the last baseline.

• **Allow for refresh lag.** Score changes can take ~24–48 hours to reflect; don't declare failure the

same day (**verify for GCC High** — Gov refresh cadence may differ).

Compliance Manager & audit evidence

• **Start with the included baseline.** The **Microsoft Data Protection Baseline** is included for

everyone; build the habit there before adding heavier templates.

• **Use the Gov-included frameworks you're entitled to.** With **G5 (Gov)**, **CMMC Levels 1–5** are

included — create the assessment that matches your contractual obligation (e.g. CMMC Level 2 for many defense contractors) and map evidence to it.

• **Remember GCC High permission handling.** In **GCC High and DoD, Compliance Manager roles are set

in Microsoft Entra ID**, not in the portal's own role UI. Manage those assignments in `entra.microsoft.us`.

• **Attach evidence, don't just check boxes.** For each improvement action, store the artifact (policy

export, screenshot, script output) that proves it. The five scripts' outputs are audit-grade evidence — archive them with dates.

• **Expect a few CM features to lag.** Items like alerts/notifications and bulk-assessment automation

may be *in development / rolling out* for GCC High; don't design a process that depends on a feature that isn't live yet (parity notes).

Least privilege & operations

• **Assign the minimum role for the task** (Security Reader to read, Security Administrator to act,

Compliance role for CM) and reserve **Global Administrator** for tenant-wide changes.

• **Use PIM for just-in-time elevation** where your Gov SKU supports it, so standing privilege is low.

• **Request only the Graph scopes you need.** Read scopes for discovery/validation/report; write scopes

only for remediation, and only when executing.

• **Log and retain.** Keep Audit (Standard/Premium) on; retain the script evidence and change tickets

for the retention period your framework requires.

Change management & documentation

• **One named object, reused everywhere.** `SEC-Baseline-Pilot`, `CA-Baseline-*` policy names, and the

named assessments are a shared vocabulary — reuse them across runbooks so the environment stays legible.

• **Keep a living posture log.** Date, action, pilot result, expansion waves, score delta. This log +

the report outputs *is* your audit-readiness story.

• **Re-baseline after major service changes** (new SKU, new workload onboarded, tenant reconfiguration)

— GCC High feature availability shifts over time as Microsoft closes parity gaps.

Deliverables Summary — Microsoft 365 Security Baseline & Audit Readiness (Government / GCC High)

Everything included in the **Government (GCC High)** edition, and where to use it.

Documents

Deliverable	Purpose
Solution Overview (`01-solution-overview.md`)	What the solution does; the **Commercial vs GCC High — what's different** map; the deployment model.
Requirements Guide (`02-requirements.md`)	Every prerequisite with *verify* + *implement-if-missing*, pinned to sovereign portals and Gov licensing.
Implementation Guide (`03-implementation.md`)	Ordered steps in the `*.us` portals, phase gates, and GCC-High caveats inline where they matter.
Testing & Validation (`05-testing.md`)	Pass/fail gates per phase, plus environment sanity checks (e.g. `USGov` confirmation).
Troubleshooting (`06-troubleshooting.md`)	GCC-High-specific failures (wrong-cloud auth, missing recommendations) and fixes.
Best Practices (`07-best-practices.md`)	Keeping posture and evidence credible over time on the sovereign cloud.
GCC High Parity Notes (`gcc-high-parity-notes.md`)	Cited reference for every "different in GCC High" claim.
Executive Summary (`executive-summary.md`)	One-page business case for decision-makers.
Deliverables Summary (this document)	Index of everything in the box.
Global Requirements — Security (`global-requirements-security.md`)	Category-level prerequisites (substitute `*.us` portals for GCC High).

PowerShell scripts

All scripts connect to **Microsoft Graph US Gov** with `-Environment USGov` (`graph.microsoft.us`). Read-only scripts make **no** changes; change-making scripts **default to** `-WhatIf`.

Script	Type	Default safety	What it does
`M365SECG-Discovery.ps1`	Read-only	N/A (read-only)	Inventories baseline Secure Score, licensing, admin roles, Conditional Access, and MFA posture on the GCC High tenant.
`M365SECG-Validation.ps1`	Read-only	N/A (read-only)	Checks that piloted baseline changes took effect; reports **PASS/FAIL per check**.
`M365SECG-Report.ps1`	Read-only	N/A (read-only)	Produces a point-in-time posture report (Secure Score summary, control states, assessment progress) for audit/leadership.
`M365SECG-Remediation.ps1`	Change	`-WhatIf`	Previews (then, with `-Execute`, applies) a small set of common improvement actions via Graph; requests only needed write scopes.
`M365SECG-Set-ScopeTargeting.ps1`	Change	`-WhatIf`	Previews (then, with `-Execute`, applies) creation/population of the pilot or wave target groups (e.g. `SEC-Baseline-Pilot`).

Named objects you create and reuse

Object	Default name	Where
Pilot security group	`SEC-Baseline-Pilot`	`entra.microsoft.us` → Groups
Baseline CA policies	`CA-Baseline-Admins-MFA`, `CA-Baseline-BlockLegacyAuth`	`entra.microsoft.us` → Conditional Access
Compliance assessment	`GCCHigh-DPB-Baseline` (and/or `GCCHigh-CMMC-L2`)	`compliance.microsoft.us` → Compliance Manager

Evidence you produce (archive for audit)

- Baseline + later **Secure Score** screenshots (`security.microsoft.us`).
- **Compliance Manager** assessment progress (`compliance.microsoft.us`).
- **Discovery / Validation / Report** script outputs (dated), each confirming `(Get-MgContext).Environment = USGov`.
- Change tickets with approver, window, pilot scope, and rollback.

Quick-start order

1. Read `01-solution-overview.md` (especially the parity map) and `gcc-high-parity-notes.md`.
2. Clear `02-requirements.md` (sovereign portals + Gov licensing + `-Environment USGov`).
3. Follow `03-implementation.md` phase by phase, clearing each gate in `05-testing.md`.
4. Use the scripts for evidence; keep `06-troubleshooting.md` and `07-best-practices.md` at hand.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

M365SECG-Discovery.ps1

Purpose: Captures a starting-state snapshot of a Microsoft 365 GCC High tenant: current Microsoft Secure Score, licensing, admin role assignments, Conditional Access policies, and MFA registration posture. Read-only. Connects to Microsoft Graph US Gov. Set your own values for placeholders such as your-tenant-id and your-output-folder when prompted or via parameters. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\M365SECG-Discovery.ps1 (Graph scopes: SecurityEvents.Read.All, Directory.Read.All, Policy.Read.All, RoleManagement.Read.Directory; connects with -Environment USGov) EXPECTED RESULTS Console summary plus a timestamped report file. If the tenant is reachable and scopes are consented, PASS: a baseline snapshot is written. If Graph connects to the wrong cloud, the script aborts before reading anything (FAIL with guidance to reconnect as USGov). .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

How to run: powershell -ExecutionPolicy Bypass -File .\M365SECG-Discovery.ps1 (Graph scopes: SecurityEvents.Read.All, Directory.Read.All, Policy.Read.All, RoleManagement.Read.Directory; connects with -Environment USGov) EXPECTED RESULTS Console summary plus a timestamped report file. If the tenant is reachable and scopes are consented, PASS: a baseline snapshot is written. If Graph connects to the wrong cloud, the script aborts before reading anything (FAIL with guidance to reconnect as USGov). .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

M365SECG-Remediation.ps1

Purpose: Applies a small set of well-understood Secure Score baseline improvement actions on a Microsoft 365 GCC High tenant via Microsoft Graph US Gov: enable a named Conditional Access policy that requires MFA for a target group, and (optionally) a policy that blocks legacy authentication. Defaults to -WhatIf (preview only) — it changes nothing until you re-run with -Execute. Set your own values for placeholders such as your-pilot-group-name. HOW TO RUN Preview : powershell -ExecutionPolicy Bypass -File .\M365SECG-Remediation.ps1 -PilotGroupName "SEC-Baseline-Pilot" Apply : powershell -ExecutionPolicy Bypass -File .\M365SECG-Remediation.ps1 -PilotGroupName "SEC-Baseline-Pilot" -Execute (Graph scopes: Policy.ReadWrite.ConditionalAccess, Group.Read.All, Policy.Read.All; connects with -Environment USGov) EXPECTED RESULTS In -WhatIf (default): a preview of each change and NO modification. With -Execute: the named policies are created/updated in report-only or enabled state and scoped to the pilot group. PASS = preview matches your approved change ticket; then execute deliberately. .NOTES White-label — the repeatable way. Defaults to -WhatIf; targets Microsoft Graph US Gov endpoints. #>

How to run: Preview : powershell -ExecutionPolicy Bypass -File .\M365SECG-Remediation.ps1 -PilotGroupName "SEC-Baseline-Pilot" Apply : powershell -ExecutionPolicy Bypass -File .\M365SECG-Remediation.ps1 -PilotGroupName "SEC-Baseline-Pilot" -Execute (Graph scopes: Policy.ReadWrite.ConditionalAccess, Group.Read.All, Policy.Read.All; connects with -Environment USGov) EXPECTED RESULTS In -WhatIf (default): a preview of each change and NO modification. With -Execute: the named policies are created/updated in report-only or enabled state and scoped to the pilot group. PASS = preview matches your approved change ticket; then execute deliberately. .NOTES White-label — the repeatable way. Defaults to -WhatIf; targets Microsoft Graph US Gov endpoints. #>

M365SECG-Report.ps1

Purpose: Produces a dated posture report for a Microsoft 365 GCC High tenant suitable for auditors and leadership: Secure Score summary, count of available control profiles, top open improvement actions, Conditional Access inventory, and Gov licensing. Read-only. Writes an HTML and a text report. Set your own values for placeholders such as your-output-folder. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\M365SECG-Report.ps1 -OutputFolder ".\M365SECG-output" (Graph scopes: SecurityEvents.Read.All, Policy.Read.All, Directory.Read.All; connects with -Environment USGov) EXPECTED RESULTS Two report files (HTML + TXT) written to the output folder, each stamped with date and the confirmed USGov environment. PASS when files are written; the console prints the summary. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

How to run: powershell -ExecutionPolicy Bypass -File .\M365SECG-Report.ps1 -OutputFolder ".\M365SECG-output" (Graph scopes: SecurityEvents.Read.All, Policy.Read.All, Directory.Read.All; connects with -Environment USGov) EXPECTED RESULTS Two report files (HTML + TXT) written to the output folder, each stamped with date and the confirmed USGov environment. PASS when files are written; the console prints the summary. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

M365SECG-Set-ScopeTargeting.ps1

Purpose: Creates and populates the security group used to scope baseline changes on a Microsoft 365 GCC High tenant (default: the pilot group), and can add members from a supplied list of user principal names. Defaults to -WhatIf (preview only) — it changes nothing until you re-run with -Execute. Set your own values for placeholders such as your-pilot-group-name and your-user-upn. HOW TO RUN Preview : powershell -ExecutionPolicy Bypass -File .\M365SECG-Set-ScopeTargeting.ps1 -GroupName "SEC-Baseline-Pilot" -MemberUpns "user1@your-domain.us","user2@your-domain.us" Apply : powershell -ExecutionPolicy Bypass -File .\M365SECG-Set-ScopeTargeting.ps1 -GroupName "SEC-Baseline-Pilot" -MemberUpns "user1@your-domain.us" -Execute (Graph scopes: Group.ReadWrite.All, User.Read.All; connects with -Environment USGov) EXPECTED RESULTS In -WhatIf (default): a preview of the group that would be created and the members that would be added, with NO change. With -Execute: the group exists and the listed members are added. PASS = preview matches your intended pilot/wave scope; then execute deliberately. .NOTES White-label — the repeatable way. Defaults to -WhatIf; targets Microsoft Graph US Gov endpoints. #>

How to run: Preview : powershell -ExecutionPolicy Bypass -File .\M365SECG-Set-ScopeTargeting.ps1 -GroupName "SEC-Baseline-Pilot" -MemberUpns "user1@your-domain.us","user2@your-domain.us" Apply : powershell -ExecutionPolicy Bypass -File .\M365SECG-Set-ScopeTargeting.ps1 -GroupName "SEC-Baseline-Pilot" -MemberUpns "user1@your-domain.us" -Execute (Graph scopes: Group.ReadWrite.All, User.Read.All; connects with -Environment USGov) EXPECTED RESULTS In -WhatIf (default): a preview of the group that would be created and the members that would be added, with NO change. With -Execute: the group exists and the listed members are added. PASS = preview matches your intended pilot/wave scope; then execute deliberately. .NOTES White-label — the repeatable way. Defaults to -WhatIf; targets Microsoft Graph US Gov endpoints. #>

M365SECG-Validation.ps1

Purpose: Confirms that the security baseline changes you piloted actually took effect on a Microsoft 365 GCC High tenant: expected Conditional Access policies exist and are enabled, they target the named pilot group, and MFA capability is trending up. Read-only. Reports PASS/FAIL per check. Set your own values

for placeholders such as your-pilot-group-name. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\M365SECG-Validation.ps1 -PilotGroupName "SEC-Baseline-Pilot" (Graph scopes: Policy.Read.All, Group.Read.All, Directory.Read.All, SecurityEvents.Read.All; connects with -Environment USGov) EXPECTED RESULTS A checklist with PASS or FAIL for each control. Overall PASS when every expected policy is present, enabled, and scoped to the pilot group. Any FAIL points you to 06-troubleshooting. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

How to run: powershell -ExecutionPolicy Bypass -File .\M365SECG-Validation.ps1 -PilotGroupName "SEC-Baseline-Pilot" (Graph scopes: Policy.Read.All, Group.Read.All, Directory.Read.All, SecurityEvents.Read.All; connects with -Environment USGov) EXPECTED RESULTS A checklist with PASS or FAIL for each control. Overall PASS when every expected policy is present, enabled, and scoped to the pilot group. Any FAIL points you to 06-troubleshooting. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>